

Vulnerability Assessment and Penetration Testing (VAPT) Report

Metasploitable3 Security Assessment

Organization : CyArt

Submitted By : Sachin – VAPT Intern

Submitted To : CyArt Team

Tools Used : Nmap, Nikto, OpenVAS, Kali Linux

Target Machine : Metasploitable3

Assessment Type : Internal Vulnerability Assessment

Date : 08 May 2026



Project Title

Vulnerability Assessment of Metasploitable3 using OpenVAS, Nmap, and Nikto

1. Executive Summary

This report presents the findings of a Vulnerability Assessment and Penetration Testing (VAPT) activity performed on the Metasploitable3 vulnerable machine in a controlled lab environment.

The assessment was conducted using Kali Linux and security tools such as:

OpenVAS

Nmap

Nikto

The objective of the assessment was to identify security vulnerabilities, exposed services, outdated software versions, weak configurations, and web application security issues.

The scan results revealed multiple Critical, High, and Medium severity vulnerabilities including:

Outdated Apache Web Server



Drupal Remote Code Execution Vulnerability

SQL Injection Vulnerabilities

Weak SSH Configuration

Exposed phpMyAdmin Panel

Directory Indexing Enabled

FTP and SSH Weak Authentication Risks

Missing HTTP Security Headers

The overall security posture of the target system is classified as:

2. Scope of Assessment

Parameter	Details
-----------	---------

Target Machine	Metasploitable3
----------------	-----------------

Target IP Address	192.168.47.134
-------------------	----------------

Testing Environment	VirtualBox Lab Environment
---------------------	----------------------------

Attacking Machine	Kali Linux
-------------------	------------

Assessment Type	Vulnerability Assessment
-----------------	--------------------------

Tools Used	OpenVAS, Nmap, Nikto
------------	----------------------

HIGH / CRITICAL RISK



3. Methodology

The assessment was conducted in the following phases:

Phase 1: Target Identification

Verified target machine IP address.

Confirmed network connectivity using ICMP ping.

Phase 2: Port and Service Enumeration

Nmap scan performed to identify:

Open ports

Running services

Software versions

Phase 3: Web Vulnerability Scanning

Nikto used for web server assessment.

Identified outdated server software, exposed directories, and missing security headers.

Phase 4: Vulnerability Assessment

OpenVAS scan conducted for comprehensive vulnerability analysis.



CVSS-based severity analysis performed.

Phase 5: Risk Assessment

Vulnerabilities categorized into:

Critical

High

Medium

Low

```
vagrant@metasploitable3-ub1404:~$ ifconfig
docker0  Link encap:Ethernet  HWaddr 02:42:8f:d0:b9:70
          inet addr:172.17.0.1  Bcast:172.17.255.255  Mask:255.255.0.0
          inet6 addr: fe80::42:8fff:fe40:b970/64 Scope:Link
          UP BROADCAST MULTICAST  MTU:1500  Metric:1
          RX packets:0 errors:0 dropped:0 overruns:0 frame:0
          TX packets:0 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:0
          RX bytes:0 (0.0 B)  TX bytes:1553 (1.5 KB)

eth0      Link encap:Ethernet  HWaddr 00:0c:29:42:d8:08
          inet addr:192.168.47.134  Bcast:192.168.47.255  Mask:255.255.255.0
          inet6 addr: fe80::20c:29ff:fe42:d808/64 Scope:Link
          UP BROADCAST RUNNING MULTICAST  MTU:1500  Metric:1
          RX packets:4618 errors:0 dropped:0 overruns:0 frame:0
          TX packets:351 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:1000
          RX bytes:6775444 (6.7 MB)  TX bytes:31334 (31.3 KB)

lo        Link encap:Local Loopback
          inet addr:127.0.0.1  Mask:255.0.0.0
          inet6 addr: ::1/128 Scope:Host
          UP LOOPBACK RUNNING  MTU:65536  Metric:1
          RX packets:221 errors:0 dropped:0 overruns:0 frame:0
          TX packets:221 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:0
          RX bytes:52739 (52.7 KB)  TX bytes:52739 (52.7 KB)

vagrant@metasploitable3-ub1404:~$ _
```

4. Connectivity Verification

The target system connectivity was verified successfully.

Step Performed

ping 192.168.47.134

Observation



The target host responded successfully to ICMP packets, confirming that the machine was reachable on the network.

```
└─$ ping 192.168.47.134
PING 192.168.47.134 (192.168.47.134) 56(84) bytes of data.
64 bytes from 192.168.47.134: icmp_seq=1 ttl=64 time=1.15 ms
64 bytes from 192.168.47.134: icmp_seq=2 ttl=64 time=0.354 ms
64 bytes from 192.168.47.134: icmp_seq=3 ttl=64 time=0.365 ms
^C
```

5. Nmap Scan Findings

Nmap scan was performed using service version detection.

Command Used

```
sudo nmap -sV 192.168.47.134
```

```
└─$ sudo nmap -sV 192.168.47.134
Starting Nmap 7.98 ( https://nmap.org ) at 2026-05-07 06:58 -0400
Nmap scan report for 192.168.47.134
Host is up (0.00036s latency).
Not shown: 991 filtered tcp ports (no-response)
PORT      STATE SERVICE        VERSION
21/tcp    open  ftp            ProFTPD 1.3.5
22/tcp    open  ssh            OpenSSH 6.6.1p1 Ubuntu 2ubuntu2.13 (Ubuntu Linux; protocol 2.0)
80/tcp    open  http           Apache httpd 2.4.7
445/tcp   open  netbios-ssn    Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
631/tcp   open  ipp            CUPS 1.7
3000/tcp   closed ppp
3306/tcp   open  mysql          MySQL (unauthorized)
8080/tcp   open  http           Jetty 8.1.7.v20120910
8181/tcp   closed intermapper
MAC Address: 00:0C:29:42:D8:08 (VMware)
Service Info: Hosts: 127.0.0.1, METASPLOITABLE3-UB1404; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 11.65 seconds
```

Open Ports and Services

Port Service Version

21/tcp	FTP	ProFTPD 1.3.5
22/tcp	SSH	OpenSSH 6.6.1p1
80/tcp	HTTP	Apache 2.4.7
445/tcp	SMB	Samba smbd 3.x - 4.x
631/tcp	IPP	CUPS 1.7
3306/tcp	MySQL	MySQL Unauthorized
8080/tcp	HTTP	Jetty 8.1.7



Analysis

The target machine exposes multiple publicly accessible services. Several services are outdated and potentially vulnerable to known exploits.

Risk Level: HIGH

6. Nikto Web Vulnerability Scan

Step Performed

nikto -h http://192.168.47.134 -output nikto_report.txt

```
+ Server: Apache/2.4.7 (Ubuntu)
+ ERROR: Failed to check for updates: 429
+ [750500] /: Directory indexing found.
+ No CGI Directories found (use '-C all' to force check all possible dirs). CGI tests skipped.
+ [600050] Apache/2.4.7 appears to be outdated (current is at least 2.4.66).
+ [013587] /: Suggested security header missing: referrer-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Referrer-Policy
+ [013587] /: Suggested security header missing: content-security-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/CSP
+ [013587] /: Suggested security header missing: permissions-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Permissions-Policy
+ [013587] /: Suggested security header missing: strict-transport-security. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Strict-Transport-Security
+ [013587] /: Suggested security header missing: x-content-type-options. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Content-Type-Options
+ [9909900] OPTIONS: Allowed HTTP Methods: POST, OPTIONS, GET, HEAD .
+ [750500] /: Directory indexing found.
+ [000327] /: Appending './' to a directory allows indexing.
+ [750500] /: Directory indexing found.
+ [000396] /: Apache on Red Hat Linux release 9 reveals the root directory listing by default if there is no index page.
+ [750500] /%2e/: Directory indexing found.
+ [000460] /%2e/: Weblogic allows source code or directory listing, upgrade to v6.0 SP1 or higher. See: https://web.archive.org/web/20171102042459/http://www.securityfocus.com/bid/2513
+ [750500] /: Directory indexing found.
+ [001407] /?PageServices: The remote server may allow directory listings through Web Publisher by forcing the server to show all files via 'open directory browsing'. Web Publisher should be disabled. See: https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-1999-0269
+ [001408] /?wp-cs-dump: The remote server may allow directory listings through Web Publisher by forcing the server to show all files via 'open directory browsing'. Web Publisher should be disabled. See: https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-1999-0269
+ [9909900] /phpmyadmin/changelog.php: Retrieved x-powered-by header: PHP/5.4.5.
+ [001796] /phpmyadmin/Changelog: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts.
+ [750500] /: Directory indexing found.
+ [003029] /: Abyss 1.03 reveals directory listing when multiple /'s are requested. See: https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2002-1078
+ [003308] /?D=A: Apache allows directory listings by requesting. See: https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2001-0731
+ [003309] /?N=D: Apache allows directory listings by requesting. See: https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2001-0731
+ [003310] /?S=A: Apache allows directory listings by requesting. See: https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2001-0731
+ [003311] /?M=A: Apache allows directory listings. Upgrade Apache or disable directory indexing. See: https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2001-0731
+ [003584] /icons/README: Apache default file found. See: https://www.vntweb.co.uk/apache-restricting-access-to-iconsreadme/
```

Index of /

Name	Last modified	Size	Description
chat/	2020-10-29 19:37	-	
drupal/	2011-07-27 20:17	-	
? payroll_app.php	2020-10-29 19:37	1.7K	
phpmyadmin/	2013-04-08 12:06	-	

Apache/2.4.7 (Ubuntu) Server at 192.168.47.134 Port 80

Nikto was used to perform web server vulnerability analysis.

Command Used

```
nikto -h http://192.168.47.134 -output nikto_report.txt
```

Web Enumeration Findings

The following directories and applications were identified:

/chat/

/drupal/

/phpmyadmin/

payroll_app.php

Detected Vulnerabilities

1. Outdated Apache Server

Apache/2.4.7 detected.

Current versions are significantly newer.

Severity: HIGH

2. Directory Indexing Enabled

Multiple directories allow listing of files.



Information disclosure risk identified.

Severity: MEDIUM

3. Missing Security Headers

The following HTTP security headers were missing:

Content-Security-Policy

X-Content-Type-Options

Permissions-Policy

Referrer-Policy

Strict-Transport-Security

Severity: MEDIUM

4. Dangerous HTTP Methods Enabled

Enabled methods:

GET

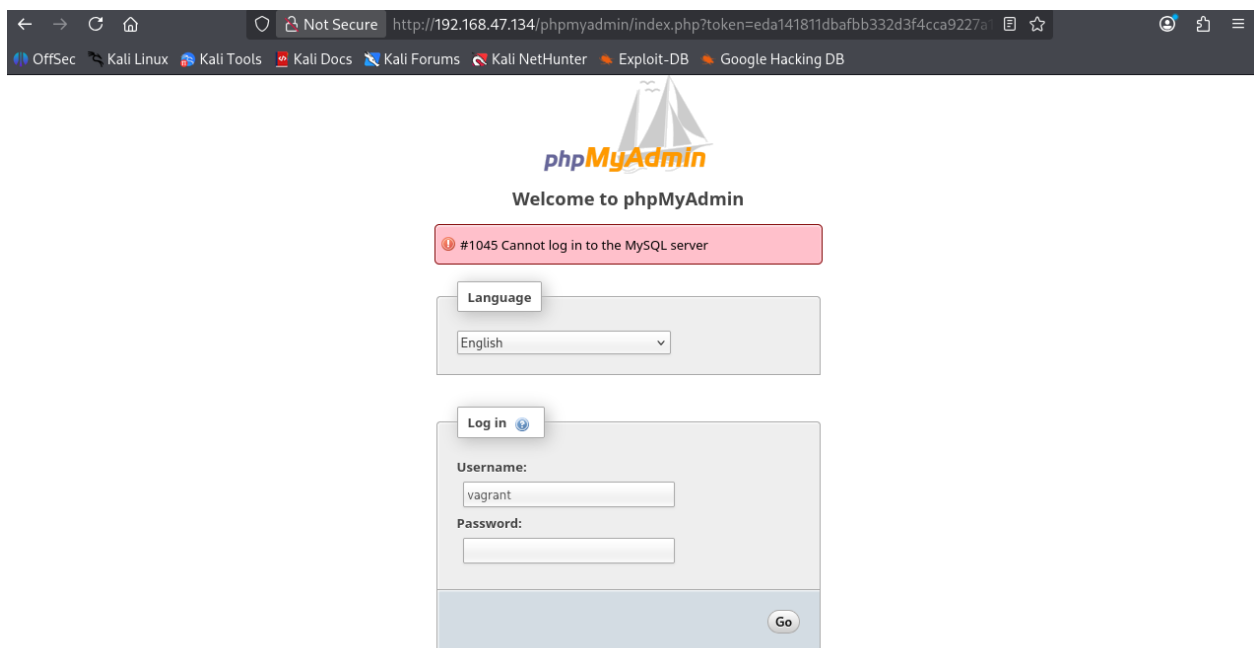
POST

OPTIONS



HEAD

Severity: MEDIUM



5. Exposed phpMyAdmin Panel

The phpMyAdmin interface was publicly accessible.

Severity: HIGH

6. Apache Default Files Accessible

Default Apache files were discovered.

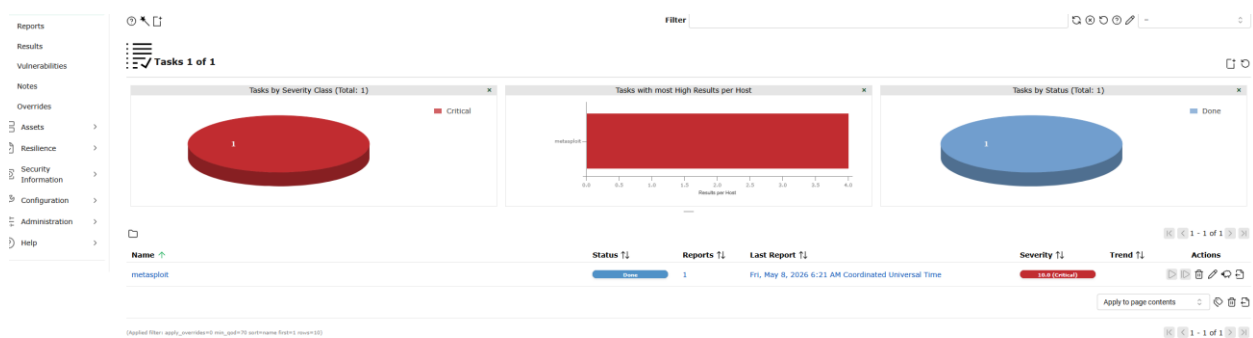
Severity: LOW



7. OpenVAS Vulnerability Findings

Step Performed

1. Opened OpenVAS web interface.
2. Created target using IP address.
3. Configured Full and Fast scan.
4. Executed vulnerability scan.
5. Downloaded generated PDF report.





Critical Vulnerabilities

Unsupported operating system detected.

Security updates may no longer be available.

CVSS Score: 10.0 Severity: CRITICAL

Vulnerable FTP service identified.

Could allow unauthorized file copying.

CVSS Score: 10.0 Severity: CRITICAL



3. Drupal Core Remote Code Execution Vulnerability

Drupal RCE vulnerability detected.

Possible remote command execution risk.

Severity: CRITICAL

4. Drupal SQL Injection Vulnerability

SQL Injection vulnerability identified.

Attackers may manipulate database queries.

Severity: HIGH

5. SSH Brute Force Login Risk

Weak/default credentials risk identified.

Severity: HIGH



6. FTP Brute Force Login Risk

FTP authentication weakness detected.

Severity: HIGH

Medium Severity Vulnerabilities

Weak SSH Key Exchange Algorithms

Weak TLS Configuration

Deprecated TLS Versions Supported

jQuery Cross-Site Scripting Vulnerabilities

Sensitive File Disclosure

Cleartext Transmission via HTTP

Unprotected Web Application Installers

8. CVSS and Risk Assessment

Risk Matrix

Vulnerability	Likelihood	Impact	Risk Level
Drupal RCE	High Critical	Critical	



SQL Injection	High	High	High
Weak SSH Configuration	Medium	High	High
Exposed phpMyAdmin	High	High	High
Missing Security Headers	Medium	Medium	Medium
Directory Listing	Medium	Medium	Medium
Default Apache Files	Low	Low	Low

9. Vulnerability Summary Table

Tool Findings

Nmap	Open ports and outdated services detected
Nikto	Web vulnerabilities and missing security headers detected
OpenVAS	Critical vulnerabilities, weak configurations, and outdated software identified

10. Remediation Recommendations

Web Server Hardening

Upgrade Apache to the latest secure version.

Disable directory indexing.

Remove default Apache files.

Drupal Security



Update Drupal CMS immediately.

Apply security patches.

Remove vulnerable plugins/modules.

SSH Security

Disable weak authentication methods.

Enforce strong passwords.

Use SSH key-based authentication.

FTP Security

Disable anonymous access.

Upgrade ProFTPD.

Use secure protocols such as SFTP.

HTTP Security Headers

Implement the following headers:

Content-Security-Policy

Strict-Transport-Security

X-Content-Type-Options

Referrer-Policy

TLS Configuration

Disable deprecated TLS versions.

Enable strong cipher suites.

11. Sources Consulted

The following resources and tools were used during the assessment:

OpenVAS Documentation

Nmap Documentation

Nikto Documentation

CVE Database

MITRE CVE Resources

Kali Linux Tools

12. Conclusion

The assessment identified multiple Critical and High severity vulnerabilities on the target system.



The presence of outdated software, weak authentication mechanisms, exposed administrative interfaces, and insecure configurations significantly increases the attack surface of the system.

Immediate remediation actions are recommended to reduce security risks and improve the overall security posture.

The system should not be deployed in a production environment without proper hardening and patch management.